

AUDITORÍA Y MONITOREO DE EVENTOS CON SQL SERVER AUDIT

SQL SERVER AUDIT: CONCEPTOS

- Cifra la base de datos completa en reposo.
- Protección contra el robo físico de medios de almacenamiento (discos).
- Cifrado a nivel de archivo (MDF, LDF).
- Transparente para aplicaciones (no requiere cambios de código).
- Uso de **Clave Maestra de Base de Datos (DMK)** y **Clave de Cifrado de Base de Datos (DEK)**

MONITOREO DE EVENTOS DE SEGURIDAD



Key Vault
(Like or Windows Certificate Store)

- Detección en tiempo real de actividades sospechosas.
- Monitoreo de intentos de inicio de sesión fallidos y exitosos.
- Generación de alertas para eventos críticos.
- Auditoría de cambios de configuración y privilegios.
- Correlación de eventos para un análisis más profundo

FLUJO DE TRABAJO DE PROTECCIÓN Y AUDITORÍA



AUTENTICACIÓN SQL Y WINDOWS: DIFERENCIAS Y PRÁCTICAS SEGURAS

AUTENTICACIÓN DE WINDOWS (INTEGRADA)

- Usa credenciales de dominio de Windows (Active Directory)
- Gestión centralizada de usuarios y grupos
- Single Sign-On (SSO) para usuarios
- Mejor seguridad por defecto (Kerberos/NTLMv2)
- Ideal para entornos corporativos y redes internas

DIFERENCIAS CLAVE

	UBICACIÓN DE CREDENCIALES: Active Directory	VS.	Base de datos SQL	
	GESTIÓN: Centralizada (Dominio)	VS.	Descentralizada (SQL Server)	
	SEGURIDAD: Más robusta por defecto	VS.	Depende de la configuración	
	USO: Redes internas corporativas	VS.	Entornos mixtos, externos	

AUTENTICACIÓN DE SQL SERVER

- Crea cuentas de usuario y contraseñas dentro de la base de datos
- Útil si los usuarios no están en un dominio de Windows
- El administrador gestiona las credenciales por separado
- Posiblemente menos segura si no se aplican políticas estrictas
- Soporta usuarios externos o en la nube

PRÁCTICAS SEGURAS RECOMENDADAS

PRÁCTICAS PARA WINDOWS

-  Usar grupos de dominio para permisos
-  Implementar Directivas de Grupo (GPOs) seguras
-  Habilitar Kerberos y deshabilitar NTLMv1
-  Auditar accesos regularmente

PRÁCTICAS PARA SQL SERVER

-  Requerir contraseñas complejas y políticas de rotación
-  Habilitar cifrado de conexiones (SSL/TLS) (si aplica)
-  Usar el principio de menor privilegio para permisos de base de datos
-  Deshabilitar la cuenta "sa" si es posible, o usar contraseñas muy fuertes

CONSEJOS GENERALES DE SEGURIDAD

-  Actualizar parches de seguridad
-  Realizar copias de seguridad regularmente
-  Supervisar registros de eventos y auditorías

CIFRADO Y PROTECCIÓN DE DATOS EN SQL SERVER: TDE Y ALWAYS ENCRYPTED

TDE (Transparent Data Encryption)

- Cifra la base de datos completa en reposo.
- Protección contra el robo físico de medios de almacenamiento (discos).
- Cifrado a nivel de archivo (MDF, LDF).
- Transparente para aplicaciones (no requiere cambios de código).
- Uso de **Clave Maestra de Base de Datos (DMK)** y **Clave de Cifrado de Base de Datos (DEK)**

ALWAYS ENCRYPTED

- Cifra datos sensibles en tránsito y en reposo.
- Las claves de cifrado nunca salen del **cliente/aplicación**.
- El SQL Server **no tiene acceso** a los datos sin cifrar.
- Ideal para entornos de nube híbrida y protección contra administradores curiosos.
- Implementación en el **controlador de cliente** (no requiere cambios en SQL Server)

FLUJO DE TRABAJO DE PROTECCIÓN



CONTROL DE ACCESO EN SQL SERVER: GRANT, DENY Y REVOKE

"GRANT" (Conceder)

- Concede permisos específicos a usuarios o roles.



- Ejemplos:
GRANT SELECT ON TablaA TO UsuarioB.
- Permite acceso



"DENY" (Denegar)

- Prohíbe explícitamente el acceso, superando cualquier GRANT.



- Ejemplos:
DENY UPDATE ON TablaC TO UsuarioD.
- Impide acceso



"REVOKE" (Revocar)

- Elimina un permiso previamente concedido o denegado.



- Ejemplos:
REVOKE GRANT SELECT ON TablaA FROM UsuarioB.
- Restaura a estado predeterminado



FLUJO DE EVALUACIÓN DE PERMISOS



CREACIÓN DE ROLES EN SQL SERVER: FIJOS Y PERSONALIZADOS

ROLES FIJOS

ROLES DE SERVIDOR (SERVER ROLES)

-  **sysadmin**
Control total de la instancia
-  **serveradmin**
Control acción de la instancia
-  **securityadmin**
Control de oecho

ROLES DE BASE DE DATOS (DATABASE ROLES)

-  **db_owner**
Configuración de db owner
-  **db_datareader**
Lectura de todas las tablas de usuario
-  **db_datawriter**
Lectura las tablas de usuario

DIFERENCIAS CLAVE

- | | | |
|---|-----|---|
|  | vs. |  |
| Configuración Rápida | | Flexibilidad |
| Permisos Predefinidos | | Total Control |
| Menos Mantenimiento | | Diseño Previo |

ROLES PERSONALIZADOS (USER-DEFINED ROLES)

DISEÑAR PERMISOS GRANULARES



- Control Preciso
- Principio de Menor Privilegio
- Jerarquía de Permisos

CREAR EL ROL



ASIGNAR PERMISOS ESPECÍFICOS



- Control Preciso
- Principio de Menor Privilegio
- Jerarquía de Permisos

AÑADIR USUARIOS AL ROL



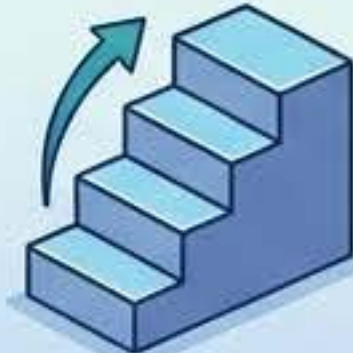
PRÁCTICAS RECOMENDADAS



Usar Roles Personalizados siempre que sea posible



Evitar el uso excesivo de sysadmin



Jerarquizar Roles para permisos acumulativos



Auditar membresías y permisos regularmente

CUENTAS DE SERVICIO Y CONFIGURACIÓN DEL SERVIDOR SQL

BUENAS PRÁCTICAS PARA SEGURIDAD Y RENDIMIENTO

SECCIÓN 1: CUENTAS DE SERVICIO SQL

TIPOS DE CUENTAS

-  **gMSA (Managed Service Accounts):** Gestión automática de contraseñas, ideal para clústeres
-  **CUENTA DE DOMINIO** Gestión centralizada de dominios, ideal para dominio
-  **CUENTA VIRTUAL** Uso documentado y parámetros para virtual

CONFIGURACIÓN DE CUENTAS



- Principio de menor privilegio
- Contraseña compleja y rotación
- Permisos locales/red específicos

AUDITORÍA DE CUENTAS



- Monitoreo de actividad
- Revisión de permisos
- Alertas de intentos fallidos

SECCIÓN 2: CONFIGURACIÓN CLAVE DEL SERVIDOR

MOTOR DE BASE DE DATOS



- Ajustar MAXDOP
- Configurar Memoria Mín/Máx
- Optimizar tempdb

SEGURIDAD DE RED



- Usar protocolos TLS
- Cifrado de conexiones (SSL/TLS)
- Configurar Firewalls

CONECTIVIDAD



- Puertos estáticos (no 1433 predet.)
- Habilitar/Deshabilitar protocolos (TCP/IP)
- Gestión de SPN

DISPONIBILIDAD/AUDITORÍA



- Estrategia de copia de seguridad
- Habilitar Auditoría de SQL Server
- Revisar Logs de Eventos

PASO A PASO: CONFIGURACIÓN EN EL SERVIDOR (Resumen)



1. CREAR gMSA
(en Active Directory)



2. ASIGNAR A SERVICIOS
(SQL Configuration Manager)



3. VERIFICAR PERMISOS
DE RED (PowerShell)



4. APLICAR CONFIGURACIÓN
DEL MOTOR (SSMS)